

Information Security Policy and Acceptable Use Standard

1. Purpose

This Information Security Policy ('Policy') establishes the minimum security requirements for protecting NimbusLogix information assets, customer data, and the systems that process them. It applies to all employees, contractors, and third parties with access to Company systems or data, regardless of location or device.

2. Account and Authentication

All employee accounts must use single sign-on (SSO) through Okta. Local-only accounts are prohibited except for documented break-glass service accounts, which require Security team approval and quarterly access reviews.

Multi-factor authentication (MFA) is mandatory for all systems that process customer data or production infrastructure. Acceptable MFA factors are: (a) hardware security keys (YubiKey or equivalent), (b) platform authenticator (Touch ID, Windows Hello), or (c) TOTP codes from an approved authenticator app. SMS-based MFA is explicitly disallowed due to SIM-swap risk.

3. Password Requirements

Passwords for any non-SSO system must be at least 14 characters in length and contain no obvious dictionary words, names, or dates. Passwords must be rotated every 90 days. Re-use of the previous 12 passwords is prohibited. All passwords must be stored in the Company-issued 1Password vault; storing passwords in browsers, notes, or plain text files is a violation of this Policy.

Service account credentials must be at least 32 characters, randomly generated, and rotated every 180 days or immediately upon any suspected exposure.

4. Acceptable Use

Company-issued laptops must run the Company-approved endpoint management agent at all times. Tampering with, disabling, or uninstalling the agent is prohibited and may result in immediate suspension of access.

Personal use of Company systems is permitted provided it is incidental, lawful, and does not consume excessive resources. Employees must not store personal media (photos, music, video) larger than 1 GB on Company-issued laptops.

5. Data Classification and Handling

NimbusLogix data is classified into four tiers: Public, Internal, Confidential, and Restricted. Customer production data is, by default, Restricted. Restricted data must never be copied to personal devices, personal cloud storage (Google Drive, Dropbox, iCloud), or removable media. Access to Restricted data is granted only through the principle of least privilege and must be reviewed quarterly by the data owner.

6. Incident Reporting

Any suspected or confirmed security incident — including lost laptops, phishing messages, accidental data exposure, or unauthorized access — must be reported to the Security team within 1 hour of discovery by emailing security@nimbuslogix.example or calling the 24x7 incident hotline. Failure to report an incident is itself

a violation of this Policy.

7. Remote Work and Travel

When working from public networks (cafes, hotels, airports), employees must connect through the Company VPN. Screen privacy filters are required when working in public. Devices must never be left unattended in public spaces; a device left unattended for more than 5 minutes must be reported as a potential theft to the Security team.